Incident Response Playbooks — Cliente A

> **Anonymization note.** This report documents real work performed under authorization from the owner. The client's name and infrastructure identifiers were replaced with placeholders (`Cliente A` , `cliente-a`) before publication. Belona Cybersecurity does not publish identifiable client data without written authorization.

Security incident response manual. Structure based on the **NIST** cycle (Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned). Follow the matching playbook when an incident occurs.

Key contacts and access (to complete)

- Technical lead: **Juan M. Morales** — contact@belonacyber.com
- Data/legal owner: **legal@cliente-a.example**
- Firebase console: https://console.firebase.google.com/project/cliente-a
- Repo: github.com//
- Data protection authority (Colombia): **SIC** — sic.gov.co

Playbook 1 — Compromised site / defacement (FIM alert)

Trigger: a FIM alert reaches Telegram ("CHANGE in ") or the FIM job turns red. 1. **Verify:** open the site in incognito and compare; check the FIM log (which file changed). Was it your own legitimate deploy? If yes → regenerate the baseline and close. If NO → 2. **Contain:** if malicious content exists, immediately redeploy the good version from Git (`firebase deploy --only hosting`) or roll back Hosting in the console. Consider maintenance mode. 3. **Eradicate:** determine how the change got in: leaked deploy credential? repo access? Rotate Firebase/GitHub credentials. Review recent Actions/commits. 4. **Recover:** confirm clean site (FIM green), regenerate baseline. 5. **Lessons:** document root cause and reinforce the failed control.

Playbook 2 — Compromised admin account / unauthorized access

Trigger: unusual activity in the panel **Logs**, unrecognized role changes, suspicious login. 1. **Immediate containment:** in Firebase → Authentication → **disable** the suspicious account. If a lawyer, remove their role in the panel (`role: none`). 2. **Investigate:** review the **Logs** (audit) section — what actions, on what resources, when. Check Cloud Logging. 3. **Eradicate:** force a password change; verify/re-enable MFA; revoke sessions. 4. **Recover:** revert unauthorized changes (use backups/PITR if data was affected). 5. **Lessons:** was MFA enough? should privileges be reduced?

Playbook 3 — Personal data breach — Colombian Law 1581 (analogous to GDPR/CCPA)

Trigger: exposure or unauthorized access to client data (consultas, cases, documents). 1. **Contain:** close the vector (rules, permissions, take down the exposed resource). 2. **Assess:** what data, how many subjects, sensitivity (financial/legal = high). 3. **Legal notification (MANDATORY in Colombia):** - Notify the **SIC** (data protection authority) of the incident. - Inform **affected data subjects** per the privacy policy. - Coordinate with legal (it is a law firm: follow the formal process). 4. **Eradicate/Recover:** fix the cause, rotate anything compromised. 5. **Lessons:** record in the compliance file.

Playbook 4 — Exposed credential / secret

Trigger: a token/key/password found in a public place (repo, site, logs) — e.g., the `.git` pentest finding. 1. **Contain:** remove the exposure immediately (delete file, redeploy). 2. **Rotate the credential NOW:** revoke and regenerate the compromised secret (GitHub token, API key, Gmail app password, etc.). Assume it was seen. 3. **Investigate:** what permissions did it have? was it used? Check access logs. 4. **Prevent:** move secrets to Secret Manager; never in the repo or Hosting.

Playbook 5 — Data loss / deletion

Trigger: missing or deleted data (accidental or malicious). 1. **Do not panic or write over the database** until assessed. 2. **Recover** per the backup runbook: recent (≤7 days) → **PITR**; up to 14 days → **daily backup**; deleted documents → **Storage versioning**. 3. Validate the restore before replacing production. 4. **Lessons:** why was it deleted? more restriction or confirmations needed?

Preparation (keep ready at all times)

- Active, **tested** backups (periodic restore test).
- FIM and Logs working (detection).
- MFA on all admin accounts.
- This document available offline.
- Know how to: disable an account, redeploy hosting, rotate secrets, restore a backup.
